
Informe Profesional de Pentesting

Actividad A08 — Hacking Etico

Cliente: INSECUR S.A. — Laboratorio: TryHackMe

Seguridad Aplicada a Sistemas de Informacion — UCH

Docente: Ing. Rodrigo Atilio Elgueta

Federico Garcia

8 de octubre de 2026

Índice

1. Datos generales	2
2. Resumen ejecutivo	2
3. Pre-pentesting	2
4. Hallazgos — Basic Pentesting	3
5. Recomendaciones	5
6. Protocolo de contingencia	5
7. Anexos	5

1. Datos generales

Campo	Valor
Cliente	INSECUR S.A.
Contratista (alumno)	Federico Garcia
DNI	
Username TryHackMe	federico.garcia.uch
Sala de eleccion (Nivel 2)	Vulniversity (pendiente)
Branch en GitHub	garcia-federico
Fecha de inicio	2026-10-08
Estado	En curso

2. Resumen ejecutivo

Sintesis

A redactar al final. Se evaluaron las salas Pentesting Fundamentals (metodologica), Basic Pentesting y Vulniversity. Este informe documenta los hallazgos de las fases de reconocimiento, escaneo y enumeracion sobre la maquina de Basic Pentesting; las fases de explotacion y post-explotacion quedan pendientes de completar.

3. Pre-pentesting

Alcance

Maquinas de laboratorio que TryHackMe asigna para **Basic Pentesting** y **Vulniversity**, accesibles por la IP que la plataforma entrega via VPN. **Pentesting Fundamentals** se incluye como formacion metodologica (teorica, sin maquina, no genera hallazgos). Fuera de alcance: todo sistema real o cualquier IP no asignada por la plataforma.

Reglas de Enfrentamiento (ROE)

Solo la IP asignada por TryHackMe via VPN. Sin ataques de denegacion de servicio. Sin salir del alcance. *Ventanas horarias y limites de trafico: a confirmar con el docente.*

Autorizacion

Autorizacion de la catedra para A08 sobre los entornos de TryHackMe indicados en la guia. No habilita acciones sobre sistemas reales.

Metodologia

NIST SP 800-115: sus fases (planificacion, descubrimiento, ataque, reporte) mapean con la estructura de este informe. Para la parte web se usa OWASP WSTG como referencia.

Autenticidad

Username THM (federico.garcia.uch) en capturas; evidencia por fase en **evidencias/**; hash SHA-256 de flags en Anexo C; commits con identidad real en la rama **garcia-federico**.

4. Hallazgos — Basic Pentesting

Objetivo: 10.64.144.216 (host BASIC2, SO Linux). **Herramientas:** nmap, enum4linux, gobuster.

Servicios detectados (nmap -sV -sC -p- -Pn):

Puerto	Servicio	Version
22/tcp	SSH	OpenSSH 8.2p1 Ubuntu
80/tcp	HTTP	Apache 2.4.41 (Ubuntu)
139/tcp	netbios-ssn	Samba (SMB)
445/tcp	microsoft-ds	Samba (SMB)
8009/tcp	ajp13	Apache JServ Protocol
8080/tcp	http-proxy	(probable Apache Tomcat)

H-01: Enumeracion de usuarios por SMB sin autenticacion

Campo	Valor
Fase	Enumeracion
Descripcion	El servicio SMB (445) permite una sesion nula (sin credenciales) que expone la lista de usuarios locales del sistema. Mediante enum4linux se obtuvieron los usuarios kay , jan y ubuntu .
Componente	Samba / SMB (puertos 139, 445)
Categoria	CWE-200 (Exposure of Sensitive Information)
Herramienta	enum4linux -a
Impacto CIA	Confidencialidad (nombres de usuario validos facilitan ataques dirigidos).
Salvaguarda	Restringir el acceso anonimo a SMB (restrict anonymous = 2 / map to guest = Never en smb.conf); limitar el puerto 445 por firewall a redes de confianza; deshabilitar SMB si el host no comparte archivos.
Riesgo residual	Bajo (tras restringir sesion nula).

H-02: SMB con firma de mensajes no obligatoria

Campo	Valor
Fase	Escaneo
Descripcion	El script smb2-security-mode de nmap reporta "Message signing enabled but not required". Permite ataques de tipo man-in-the-middle / relay sobre el trafico SMB.
Componente	Samba / SMB
Categoria	CWE-300 (Channel Accessible by Non-Endpoint)
Herramienta	nmap -sC
Impacto CIA	Integridad y Confidencialidad.
Salvaguarda	Exigir firma SMB (<code>server signing = mandatory</code>); segmentar la red para reducir exposicion a relay.
Riesgo residual	Bajo.

H-03: Directorio web no enlazado expuesto

Campo	Valor
Fase	Escaneo / Enumeracion
Descripcion	Enumeracion de directorios con gobuster sobre el puerto 80 revelo el directorio <code>/development/</code> (HTTP 301), no enlazado desde la pagina principal.
Componente	Apache 2.4.41 (puerto 80)
Categoria	CWE-538 (File/Directory Information Exposure)
Herramienta	gobuster dir
Impacto CIA	Confidencialidad (posible exposicion de informacion interna).
Salvaguarda	Remover o proteger con autenticacion los directorios de desarrollo en produccion; configurar control de acceso en Apache; revisar permisos de los recursos publicados.
Riesgo residual	Medio (hasta revisar el contenido del directorio).

Fases pendientes de completar

Explotacion (brute force de credenciales SSH sobre el usuario jan) y post-explotacion (escalada de privilegios) quedan iniciadas y pendientes. El brute force por SSH se vio limitado por la latencia de la VPN; se retomara con la maquina reiniciada. Vulniversity (sala de eleccion) tambien queda pendiente.

5. Recomendaciones**Tecnicas**

Restringir sesion nula y exigir firma en SMB; limitar por firewall los puertos 445, 8009 y 8080 a redes de confianza; proteger o remover /development/; mantener actualizados Apache, OpenSSH y Samba.

Administrativas

Politica de gestion de parches; revision periodica de servicios expuestos; principio de minima exposicion (cerrar servicios no utilizados).

6. Protocolo de contingencia**Escenario y RTO/RPO**

*A completar: escenario de interrupcion de servicio, deteccion, contencion, recuperacion, comunicacion. RTO:
RPO:*

7. Anexos**Anexo A — Bitacora**

Comandos en bitacora/.

Anexo B — Capturas

En evidencias/: escaneo_nmap.png, enum_usuarios_smb.png, gobuster_development.png.
(Pendiente de pasar desde Kali a la carpeta del repo.)

Anexo C — Hashes de flags

```
# flag_id  sha256_hash
# (pendiente: completar al obtener flags)
```

Anexo D — Declaracion etica

Declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos controlados y con fines academicos.

Firma	Fecha
--	--